

MID-STATE TECHNICAL COLLEGE • IT PROGRAMS

Basic Configuration and User Management

Unit 3 • Virtualization and Software Defined Data Centers (10-150-130)



Learning Outcomes

By the end of this unit, you will be able to:



Configure a Proxmox VE host after installation

Set package repositories, apply updates, and verify time, DNS, and management networking.



Manage users, groups, and authentication realms

Create accounts in the PAM and Proxmox VE realms, integrate directories, and issue scoped API tokens.



Implement role-based access control

Grant roles to groups on paths and resource pools, then verify the effective permissions.



Harden the management plane

Enforce two-factor authentication, restrict access with the firewall, and monitor administrative activity.

LESSON 1

Post-Installation Configuration



The Post-Install Checklist

Complete these before the first guest is created — each one is harder to fix with workloads running.

- **Repositories** — point APT at the repository you are licensed for, and disable the ones you are not.
- **Updates** — bring the host fully current and reboot into the newest kernel.
- **Time** — confirm chrony is synchronizing against reliable sources.
- **Name resolution** — the hostname must resolve to the management IP, and DNS must answer.
- **Networking** — separate traffic types and plan bridges, VLANs, and bonds before guests depend on them.



Record each decision in your build notes — Lab 3 grades the configuration and the documentation together.

Package Repositories

Proxmox VE layers its own repositories on top of the standard Debian 13 "Trixie" sources:

Repository	Key required?	Purpose	POD hosts
pve-enterprise	Yes	Most heavily tested packages; production with support	Disabled
pve-no-subscription	No	Same packages, released earlier; labs and non-critical use	Enabled
pve-test	No	Pre-release packages for testing new features	Not used
ceph	Varies	Ceph packages, enterprise or no-subscription channel	Disabled

Manage these from Node → Updates → Repositories, which also flags a missing or misconfigured Proxmox repository.

Repository Files in Proxmox VE 9

Version 9 uses multi-line deb822 `.sources` files instead of single-line `.list` entries:

```
# /etc/apt/sources.list.d/proxmox.sources
Types: deb
URIs: http://download.proxmox.com/debian/pve
Suites: trixie
Components: pve-no-subscription
Signed-By: /usr/share/keyrings/proxmox-archive-keyring.gpg
```

- Disable a source by adding `Enabled: false` to its stanza — `pve-enterprise.sources` and `ceph.sources` on our hosts.
- `Suites`: names the Debian release; it changes at every major Proxmox VE upgrade.
- Packages are verified against the Proxmox archive key installed with the ISO.

Keeping the Host Patched

- Refresh and upgrade with `apt update` followed by `apt full-upgrade` — or use Node → Updates in the GUI.
- Never use `apt upgrade` on a Proxmox host; it cannot remove or replace packages and can leave the host half-upgraded.
- Reboot after kernel updates, then confirm the running version with `pveversion -v`.
- Watch the Proxmox security advisories (PSA) forum for fixes that warrant an unscheduled update.



SECURITY FOCUS

Proxmox VE 9.2 shipped fixes for multiple Linux kernel local privilege-escalation vulnerabilities. An unpatched host is exposed to every one of them.

Why it matters: On a hypervisor, a local foothold that becomes root controls every guest on the host.

Time Synchronization

- **chrony** is the default time daemon; its configuration lives in `/etc/chrony/chrony.conf`.
- Configure at least three sources so one bad or unreachable server can be outvoted.
- Check synchronization with `chronyc sources -v` and `chronyc tracking`; set the zone with `timedatectl`.
- Accurate time underpins cluster membership, TLS certificate validity, and log correlation across hosts.



Time is a security control

TOTP codes change every 30 seconds, so a drifting clock breaks two-factor logins. Kerberos in Active Directory rejects clocks more than five minutes apart by default.

Hostname and DNS Resolution

Three files define how the host names itself and finds everything else — editable from Node → System:

File	Purpose	POD value
<code>/etc/hostname</code>	Short hostname of the node	<code>XXPODxx-Host1</code>
<code>/etc/hosts</code>	Maps the hostname to the management IP	<code>10.xx.3.yy XXPODxx-Host1.mstclab.local XXPODxx-Host1</code>
<code>/etc/resolv.conf</code>	DNS resolver and search domain	<code>search mstclab.local · nameserver 10.xx.2.254</code>

The hostname must resolve to the management IP, never 127.0.1.1 — the cluster filesystem and web proxy depend on it. Verify with `hostname --ip-address`.

LIVE DEMO

Open Node → System → Hosts and DNS on a POD host and match each value to this table.

Separating Traffic Types

Production hosts separate traffic so one workload cannot starve or expose another:

Traffic	What it carries	What it needs	Isolation approach
Management	Web UI, API, SSH	Reachable only by admins	Dedicated VLAN
Storage	iSCSI and NFS	Bandwidth, MTU 9000	Dedicated NICs
Cluster	Corosync membership	Low, stable latency	Redundant dedicated links
Guest	VM and container traffic	Segmentation per tenant	VLAN-tagged bridges
Migration	Live-migration memory copy	Bandwidth	Dedicated or storage network

Our POD hosts begin with the management network; storage networking is added in the SAN labs.

Bridges, VLANs, and Bonds

Linux bridges and VLANs

- `vmbr0`, created by the installer, is the management bridge.
- **VLAN aware** lets one bridge carry many tagged VLANs.
- Each guest NIC takes a VLAN tag instead of needing its own bridge.

Bonds (link aggregation)

- `active-backup` — failover only; no switch configuration.
- `802.3ad` (LACP) — aggregation plus failover; the switch must match.
- Build the bond first, then put the bridge on top of it.

Network edits can cut you off: a wrong change to `vmbr0` drops the web UI the moment you click Apply Configuration. Review the pending diff and keep iLO5 open first.

Proxmox VE can rate-limit individual guest NICs; true QoS prioritization is configured on the physical switches.

LESSON 2

Users, Realms, and Authentication



Every User Belongs to a Realm

Proxmox VE identifies every account as a username plus the realm that authenticates it:

```
root@pam           # Linux system root: always present, cannot be deleted
student01@pve      # account in the Proxmox VE authentication server
jsmith@mstclab     # user from a directory realm named mstclab
jsmith@pve!automation # API token named automation, owned by jsmith@pve
```

- User attributes live in `/etc/pve/user.cfg`, replicated to every cluster node.
- Passwords are never stored there — the realm holds or checks them.
- `root@pam` is an unconfined administrator: use it to bootstrap, not for daily work.

Disabling is not logging out

Disabling, deleting, or expiring a user blocks new logins and tasks. Sessions and consoles already running keep going.

Authentication Realms

A realm decides where credentials are checked. Five realm types are available:

Realm	Credentials checked against	Best fit	Setup
Linux PAM	Host accounts on each node	Administrators needing a shell	Built in
Proxmox VE	Hashes replicated cluster-wide	Web and API users, labs	Built in
LDAP	External directory, e.g. OpenLDAP	Central Linux or Unix identity	Datacenter → Realms
Active Directory	Windows domain controllers	Windows-centric organizations	Datacenter → Realms
OpenID Connect	External identity provider	Single sign-on with an existing IdP	Datacenter → Realms

Realm definitions live in `/etc/pve/domains.cfg`. OpenID Connect works with providers such as Keycloak, Google, and Microsoft Entra ID.

Linux PAM vs. Proxmox VE Realm

Linux PAM (@pam)

- Real Linux accounts, created with `adduser` on the host.
- The account must exist on every node it logs in to.
- GUI password changes apply only to the local node.

Proxmox VE (@pve)

- Exists only inside Proxmox VE — no shell account.
- Passwords are hashed and replicated cluster-wide.
- Users can change their own password in the GUI.

Rule of thumb: create @pve accounts for people who only need the web UI or API. Reserve @pam for administrators who genuinely need the host shell.

The difference is blast radius: a compromised @pam administrator can reach the host shell, while a compromised @pve operator cannot.

Creating Users and Groups

Everything in the Permissions panel has a pveum equivalent — both call the same REST API:

```
pveum group add operators --comment "VM operators"
pveum user add student01@pve --password --groups operators
pveum user modify student01@pve --enable 0          # disable the account
pveum passwd student01@pve                          # reset a password
pveum user list
```

- **Groups are the preferred subject** for permissions — grant to the group, then manage membership.
- Set an **expiration date** on temporary and lab accounts so they retire themselves.
- `pveum help user add` lists every option for any subcommand.

LIVE DEMO

Create an operators group and student01@pve in the GUI, then repeat it with pveum.

LDAP and Active Directory Realms

- **LDAP** realms search a **base DN** using a user attribute such as `uid`; **AD** realms need the domain and a domain controller.
- A **bind user** queries the directory; its password is stored in `/etc/pve/priv/realm/<realm>.pw`.
- Configure a fallback server, and use LDAPS or STARTTLS with certificate verification on.
- Directory users still need a Proxmox VE user entry before they can log in.



Sync, don't hand-enter

`pveum realm sync <realm>` imports users and groups into `user.cfg`.

Preview with dry-run, and enable remove-vanished so departed staff lose access.

AD compares usernames case-insensitively — set `--case-sensitive 0` on AD realms so Proxmox VE matches.

API Tokens for Automation

- Tokens give tools stateless REST API access, sent as `PVEAPIToken=USER@REALM!TOKENID=SECRET`.
- **Privilege separation** is the default: effective rights are the intersection of the user's and the token's ACLs.
- The secret is shown once. Set an expiration so abandoned automation stops working.
- Version 9.2 can regenerate a leaked secret in place, keeping the token's ACLs.



SECURITY FOCUS

Give each integration its own privilege-separated token, scoped to the paths it needs. Monitoring gets PVEAuditor, not Administrator.

Why it matters: A token pasted into a script is a credential. With full privileges, whoever finds it owns the cluster.

LESSON 3

Roles, Permissions, and Pools



A Permission Is a Triple

Every access-control entry answers three questions — who, what, and where:



Who • Subject

A user, a group, or an API token.
Groups are the preferred subject.



What • Role

A named set of privileges, such as
PVEVMUser.



Where • Path

An object in the resource tree, such
as /vms/101.

```
pveum acl modify /pool/lab01 --groups operators --roles PVEVMUser
```

Read it aloud: members of operators hold PVEVMUser on everything in pool lab01.

Built-in Roles

Proxmox VE ships predefined roles that satisfy most requirements:

Role	What it allows	Typical holder
Administrator	Everything, including permissions and system settings	Senior administrators
PVEAdmin	Most tasks, but not system settings, realms, or permissions	Day-to-day administrators
PVEVMAdmin	Full administration of virtual machines	Application owners
PVEVMUser	View, back up, console, power, and change CD-ROM	Operators, lab students
PVEAuditor	Read-only access	Monitoring, compliance
NoAccess	Nothing — explicitly blocks other roles	Exceptions to broad grants

Role names beginning with PVE are built in and reserved. See all of them under Datacenter → Permissions → Roles.

Privileges and Custom Roles

A privilege is one permitted action; a role bundles privileges so they are granted as a unit.

- Privileges are namespaced by object: `Sys.*`, `VM.*`, `Datastore.*`, `SDN.*`, `Pool.*`.
- Build a custom role when nothing fits — add what is needed rather than trimming Administrator.
- `Permissions.Modify` and `Sys.Modify` are keys to the kingdom; grant them sparingly.

```
pveum role add VM_Power-only --privs "VM.PowerMgmt VM.Console"
```

Proxmox VE 9 changed privileges

VM.Monitor was removed; guest agent access is split into `VM.GuestAgent.*` privileges.

New `VM.Replicate` governs storage replication.

Creating privileged containers now requires `Sys.Modify`.

Re-check custom roles after every upgrade.

Permission Paths

Permissions attach to objects addressed by file-system-like paths:

Path	Covers	Example grant
/	The entire datacenter	auditors → PVEAuditor
/vms	All VMs and containers	operators → PVEVMUser
/vms/{vmid}	One specific guest	app-owners → PVEVMAdmin on /vms/105
/storage/{storeid}	One storage	students → PVEDatastoreUser on /storage/VMLab-NFS
/pool/{poolname}	Every member of a resource pool	lab01-students → PVEVMAdmin on /pool/lab01
/nodes/{node}	One host's system functions	node-admins → PVESysAdmin

Paths form a tree: a grant at /vms flows down to /vms/105 unless something deeper overrides it.

How Grants Combine

When grants overlap, Proxmox VE resolves them with four rules:

- **Deeper wins.** A grant on `/vms/105` replaces what was inherited from `/vms` or `/`.
- **User beats group.** A grant on the individual user replaces their group grants.
- **Groups add up.** Every group the user belongs to contributes its grants.
- **NoAccess cancels.** NoAccess on a path removes every other role there.



Worked example

operators hold PVEVMUser on `/vms`. Add NoAccess for operators on `/vms/900`, the payroll server. Operators keep every guest except that one.

LIVE DEMO

Verify with `pveum user permissions student01@pve --path /vms/900`.

Resource Pools

A resource pool groups guests and storage so a single grant covers all of them:

```
pveum pool add lab01 --comment "POD 01 lab resources"
pveum pool modify lab01 --vms 101,102 --storage VMLab-NFS
pveum group add lab01-students
pveum acl modify /pool/lab01 --groups lab01-students --roles PVEVMAdmin
```

- Guests added to the pool inherit its permissions immediately — no per-VM grants.
- Pools define **what**; groups define **who**. Together they keep the ACL list short.
- Pools can be nested to mirror departments, courses, or sites.

LIVE DEMO

Build pool lab01, add two guests, and log in as a pool member to see only those resources.

Least Privilege in Practice

- Grant to **groups**, at the **narrowest path** that works — pools make narrow paths practical.
- Start from PVEAuditor or PVEVMUser and add; never start from Administrator.
- Keep `root@pam` for bootstrap and break-glass; administrators use named accounts.
- Review each term with `pveum user permissions`, which shows the effective result.



SECURITY FOCUS

Named accounts in an Administrator group carry the same power as `root@pam`, plus an audit trail naming who acted.

Why it matters: When everyone shares `root@pam`, the task log cannot tell you who deleted the production VM.

LESSON 4

Security Hardening



Defense in Depth

Hardening stacks independent controls so a single failure does not become a breach:

Layer	Threat it addresses	Proxmox VE controls
Network	Unauthorized reach to management services	Management VLAN, firewall, management IPSet
Host	Exploited OS packages and services	Prompt patching, SSH keys, fail2ban
Identity	Stolen or guessed credentials	Right realm, two-factor authentication, token expiry
Authorization	Over-privileged accounts	Roles on narrow paths, pools, NoAccess
Detection	Misuse that goes unnoticed	Task log, journal, notifications, remote syslog

No single layer is sufficient — attackers need only one gap, defenders must close all of them.

Two-Factor Authentication Options

A second factor protects accounts whose passwords have leaked or been guessed:

Factor	How it works	What it needs
TOTP	Six-digit code from a shared secret and the clock, new every 30 seconds	Authenticator app, accurate time
WebAuthn	Security key or device authenticator signs a login challenge	Trusted HTTPS certificate, WebAuthn settings
Recovery keys	Single-use codes, printed or stored in a vault	Nothing — one set per user
YubiKey OTP	Realm-enforced one-time password from a YubiKey	Yubico API credentials

Register at least two factors, one of them recovery keys. Legacy U2F still works, but WebAuthn replaces it.

Enforcement and Lockout

- **Realm-enforced** TFA (TOTP or YubiKey) makes a second factor mandatory for every user in that realm.
- Users can also opt in individually from Datacenter → Permissions → Two Factor.
- Eight failed TOTP attempts disable that user's TOTP; WebAuthn and recovery keys allow 100, then block for an hour.
- Clear a lockout with `pveum user tfa unlock student01@pve`.



Enforce with care

Enforcing TFA on a realm immediately blocks users who have not enrolled. Enroll and test an admin account first.

After a TOTP lockout, require a password change.

LIVE DEMO

Enroll TOTP for student01@pve with a phone app, then generate recovery keys.

The Proxmox VE Firewall

- Rules apply at the **datacenter**, **node**, and **guest** levels, stored under `/etc/pve/firewall/`.
- Disabled by default; once enabled, inbound traffic not explicitly allowed is dropped.
- An IPSet named `management` defines admin hosts allowed to reach the GUI, SSH, and consoles.
- Security groups and macros keep rule sets consistent across many guests.



Don't lock yourself out

Populate and verify the management IPSet, then enable the datacenter firewall.

If it goes wrong, the iLO5 console and `pve-firewall stop` are your way back in.

The nftables-based firewall remains a technology preview in 9.2; the iptables-based service is still the default.

Ports to Know

Allow only what each network needs to reach:

Port	Proto	Service	Expose to
8006	TCP	Web interface and REST API over HTTPS	Management network
22	TCP	SSH, also used for cluster actions	Admins and cluster nodes
5900–5999	TCP	VNC web console (WebSocket)	Management network
3128	TCP	SPICE proxy	Management network
5405–5412	UDP	Corosync cluster traffic	Cluster network only
60000–60050	TCP	Live migration	Cluster or migration network

Never publish 8006 to the internet — reach it through a VPN or jump host on the management network.

SSH Hardening and fail2ban

SSH

- Use key-based authentication; disable passwords once keys work.
- `PermitRootLogin prohibit-password` keeps key-only root access.
- Restrict port 22 to the management network.

fail2ban

- Bans source IPs after repeated authentication failures.
- A web UI jail matches `pvedaemon` failures in the systemd journal.
- Reacts to attacks; the firewall prevents them.

Clustered nodes talk as root over SSH: removing root key access or rotating host keys carelessly breaks migration. Test changes on one node first.

fail2ban is not installed by default — add it with `apt install fail2ban`, then define a jail for the web interface.

Audit Logging and Monitoring

- The **task log** records each operation with the user who started it — another reason for named accounts.
- Login failures land in the journal: `journalctl -u pvedaemon -u pveproxy`.
- Forward the journal to central syslog or a SIEM so logs survive a compromised host.
- Datacenter → Notifications sends alerts through SMTP, Gotify, or webhooks.



Know the gap

A cluster-wide audit log with actor attribution is still on the Proxmox roadmap. Until it ships, forwarded logs are your audit trail.

Since 9.2, a failed login returns the same message for a bad username or password, revealing nothing about which accounts exist.

Security Focus: The Management Plane

Every lesson in this unit protects the same asset — the ability to change the hypervisor.



SECURITY FOCUS

Configuration: trusted repositories, full upgrades, synchronized clocks, and a management network only administrators can reach.

Identity: named accounts in the right realm, a second factor for everyone, and scoped API tokens for automation.

Authorization: roles granted to groups on the narrowest path, with NoAccess to carve out exceptions.

Detection: logs that leave the host, and a task log that names a person rather than root.

Why it matters: Whoever controls the management plane controls every guest on it — their data, their uptime, and their backups.

Hands-On Lab 3: Basic Setup and Configuration

POD lab · your assigned HP DL20 Gen 10 host · <https://XXPODxx-Host1.mstclab.local:8006>

- Disable the enterprise and Ceph repositories, enable no-subscription, and fully update the host.
- Verify time synchronization with chrony and confirm the correct time zone.
- Confirm DNS uses 10.xx.2.254 with the mstclab.local search domain, and that the hostname resolves correctly.
- Customize the web interface and set the root@pam e-mail address for system notifications.
- Record every change and the reason for it in your build notes.



Individual assignment details and submission are in Blackboard Ultra. Graded on the live host and build notes.

Hands-On Lab 4: Users, Groups, and Permissions

POD lab · your assigned host · work as root@pam, verify as each user you create

- Practice password changes for accounts in both the Linux PAM and Proxmox VE realms.
- Create users in each realm and compare what each account can reach.
- Build groups and a resource pool, grant built-in roles, and verify effective permissions.
- Enable TOTP two-factor authentication on a test account and generate recovery keys.
- Integrate an LDAP directory realm and synchronize its users and groups.



Individual assignment details and submission are in Blackboard Ultra. Each permission must be demonstrated, not described.

Key Takeaways



Trusted repositories, full upgrades, accurate time, and a resolvable hostname come before any guest.



Every account is user@realm — @pve for web and API users, @pam only for shell administrators.



A permission is subject + role + path; grant to groups on the narrowest path that works.



Layer the defenses: two-factor authentication, a management-only firewall, hardened SSH, and logs that leave the host.

MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Questions?

Unit 3 · Basic Configuration and User Management